Roteiro – Laboratório de Análise de Phishing

Regras de segurança (leia antes de começar)

- Os e-mails deste laboratório são **phishing real**. Trabalhe com eles **somente no Google Colab**. Nunca baixe os arquivos para o seu computador.
- **Nunca clique** em links nem abra anexos das amostras.
- Ao anotar um link, domínio ou IP, use sempre **defang**: `hxxps://site[.]com` e `192.168.0[.]1`.
- No urlscan.io e no VirusTotal, **pesquise primeiro**. Só envie algo novo se o professor autorizar, e no urlscan sempre como *Private*.

Como usar o Google Colab

1. Acesse **colab.research.google.com** com sua conta Google e clique em **Novo notebook**.
2. Cada caixa de código é uma **célula**. Cole o comando e aperte **Shift+Enter** para rodar.
3. Para criar uma célula nova, clique em **+ Código**.
4. Comandos Linux começam com `!`. `%cd` muda de pasta. Uma célula que começa com `%%bash` roda várias linhas de Bash.
5. Se a sessão expirar ou der erro de "No such file", clique em **Runtime → Run all** para rodar tudo de novo, de cima para baixo.
6. Os arquivos somem quando a sessão fecha: **copie suas respostas para a ficha** antes de sair.

Lab 1: Dissecando e-mails

Objetivo: ler o código-fonte de e-mails de phishing reais e extrair as informações que um analista de SOC usa.

As amostras vêm do projeto **phishing_pot** (github.com/rf-peixoto/phishing_pot): mais de 12 mil e-mails de phishing reais, capturados em armadilhas (honeypots), no formato `.eml`.

Passo 1 – Baixar as amostras

Na primeira célula:

```
!git clone --depth 1 https://github.com/rf-peixoto/phishing_pot.git
%cd /content/phishing_pot/email
!ls | head -20
```

Vai aparecer uma lista de arquivos `sample-1.eml`, `sample-10.eml` etc.

Passo 2 – Leitura manual com Bash

Escolha **3 amostras** (troque `sample-1` pelo número que quiser, por exemplo `sample-57`). Numa nova célula:

```
%%bash
cd /content/phishing_pot/email
grep -iE '^(From|Reply-To|Return-Path|Subject|Date|Message-ID):' sample-1.eml
grep -i -A2 '^Received:' sample-1.eml
grep -i -A3 '^Authentication-Results:' sample-1.eml
grep -oE 'https?://[^"<> ]+' sample-1.eml | sort -u
```

Para ver o e-mail inteiro como texto: `!cat sample-1.eml`

Pergunte-se: o `grep` encontrou links? Se não encontrou, procure no e-mail a linha `Content-Transfer-Encoding`. O corpo pode estar codificado.

Passo 3 – Decodificar o corpo

Se o corpo estiver em **base64** (um bloco grande de letras e números sem espaços), copie um trecho e decodifique no **CyberChef** (gchq.github.io/CyberChef), com a receita **From Base64**. O que aparece?

Passo 4 – Automatizar com Python

Numa nova célula, cole **tudo** abaixo, incluindo a primeira linha, e rode. Deve aparecer `Writing analisa_eml.py`.

```
%%writefile analisa_eml.py
import sys, re, hashlib, email
from email import policy

msg = email.message_from_binary_file(open(sys.argv[1], 'rb'), policy=policy.default)

print("== CABECALHOS ==")
for h in ['From', 'Reply-To', 'Return-Path', 'To', 'Subject', 'Date', 'Message-ID',
'X-Originating-IP']:
    print(f"{h}: {msg.get(h)}")

print("\n== RECEIVED (do primeiro salto ao ultimo) ==")
for i, r in enumerate(reversed(msg.get_all('Received', [])), 1):
    print(f"{i}. {' '.join(str(r).split())[:200]}")

print("\n== AUTENTICACAO ==")
print(msg.get('Authentication-Results'))

print("\n== URLS ==")
urls = set()
for part in msg.walk():
    if part.get_content_maintype() == 'text':
        try:
            urls.update(re.findall(r'https?://[^\s"\'<>]+', part.get_content()))
        except Exception:
            pass
for u in sorted(urls):
    print(u.replace('http', 'hxxp', 1).replace('.', '[.]'))

print("\n== ANEXOS ==")
for part in msg.walk():
    nome = part.get_filename()
```

```
    if nome:
        dados = part.get_payload(decode=True) or b''
        print(f"{nome} | {part.get_content_type()} | {len(dados)} bytes | SHA256
{hashlib.sha256(dados).hexdigest()}")
```

Depois, numa nova célula, rode para cada uma das suas 3 amostras:

```
!python3 analisa_eml.py sample-1.eml
```

O script mostra os cabeçalhos, o caminho do e-mail (do primeiro servidor ao último), a autenticação, as URLs já com defang e o hash SHA-256 dos anexos, sem abrir nada.

Ficha de entrega – Lab 1

Campo	Amostra 1 (nº10)	Amostra 2 (nº1000)	Amostra 3 (nº10001)
Assunto e marca imitada	Microsoft account unusual signin activity (Microsoft)	Liberação de IRPF - 6NwLyfzWcsNerv0 / Receita Federal ou Banco do Brasil (indicado pelo "[BB]")	100 Balls. $5 No Deposit Required ! / Imitação de site de apostas (free spin)
From	"Microsoft account team", _ <no-reply@access-accsecurity.com>	"[BB] - Seu saldo foi liberado - Código: 110843396471308 51921" <prestonconstance587@gmail.com>	free spin <lee.white@bnvftbfantay.onmicrosoft.com>.
Reply-To	sotrecognizd@gmail.com	None	None.
Return-Path	bounce@thcultarfdes.co.uk	prestonconstance587@gmail.com	lee.white@bnvftbfantay.onmicrosoft.com.
IP e host do primeiro salto	thcultarfdes.co.uk (89.144.44.2)	a3.domain ([20.97.213.223]) by smtp.gmail.com	268422111889 named unknown by gmailapi.google.com.
SPF / DKIM / DMARC	spf=none, dkim=none, dmarc=permerror	spf=pass, dkim=pass, dmarc=pass	spf=fail, dkim=pass, dmarc=none
URLs (com defang)	hxxp://thebandalisty[.]com/track/o43062rdzGz18708448Gdrw1821	Nenhuma	Várias iniciadas em hxxp://woondsplay[.]com e hxxps://i[.]imgur[.]com

Campo	Amostra 1 (nº10)	Amostra 2 (nº1000)	Amostra 3 (nº10001)
	750fYo33632dSjh176		
Anexos (nome, tipo, SHA-256)	Nenhum anexo	csWuYjyqO2IR.pdf | application/pdf | 97566 bytes | SHA256 cfc5fbc759dcc599c8329dd94f9364394c7b1e875d6ff515c7337e00fb1f30cf	Nenhum
Gatilho de engenharia social	Urgência e medo ao alertar sobre uma atividade de login incomum na conta.	Curiosidade e ganância, sugerindo a liberação de saldo financeiro ou restituição de imposto.	Ganância e senso de oportunidade, oferecendo dinheiro grátis sem necessidade de depósito.
Por que é phishing? (1 frase)	A mensagem simula ser da Microsoft, mas utiliza remetente e domínio de resposta não oficiais, além de conter um link malicioso e falhar na autenticação DMARC.	Usa um e-mail comum do Gmail para um assunto governamental/bancário e envia um anexo em PDF suspeito.	O remetente falha na validação de origem (SPF fail) e tenta redirecionar a vítima por meio de múltiplos links obscuros